Rhombus Botnet Investigation - Student Briefing

1. Malware Overview

- Family / type: Rhombus, a Linux DDoS botnet targeting VPS and IoT devices.
- Behaviour: The malware exhibits persistence and dropper capabilities, with C2 communication but no lateral movement or exfiltration. It targets Linux platforms.
- Associated MITRE ATT&CK techniques:
- Persistence: T1547.001 (Registry Run Keys / Startup Folder)
- Command and Control: T1071 (Application Layer Protocol)
- Exploitation: T1200 (Hardware Additions)

2. Exercise Objective

- The learning goal of this cyber-range exercise is to investigate and remediate a Rhombus botnet infection on Linux hosts. This scenario is designed for an Intermediate difficulty level with a Defence-oriented approach, aligning with the Incident Response NICE work role.
- By the end of this exercise, a successful trainee will have demonstrated the ability to enumerate and analyze running services and systemd timers, investigate network connections, identify and disable persistence mechanisms, contain threats by blocking unauthorized network communication, and terminate malicious processes to remediate the compromise.

3. Sandbox Topology & Malware Emulation

- Network Layout:

```
  [botnet-switch: 192.168.70.0/24]
    |
    |-- c2-server (192.168.70.5)
    |-- bot1 (192.168.70.10)
    |-- bot2 (192.168.70.11)
  [victim-switch: 192.168.80.0/24]
    |
    |-- victim (192.168.80.100)
```

- Hosts:
- c2-server: The command-and-control server running the botnet-c2-listener.service on port 2222.
- bot1: A compromised host running the bot-beacon.service and bot-beacon.timer, and the bot-flood.service and bot-flood.timer.
- bot2: A compromised host running the bot-beacon.service and bot-beacon.timer, and the bot-flood.service and bot-flood.timer.
- victim: The target of the DDoS flood from bot1 and bot2.

- Malware Emulation:
- C2 Beacon Service: The bot-beacon.service on bot1 and bot2 is responsible for sending periodic beacons to the C2 server (c2-server) on port 2222. The beacon script is located at /usr/local/lib/.botcache/beacon.sh.
- Persistence Mechanism: The system-update-checker.timer and system-update-checker.service are used to maintain persistence on the compromised hosts.
- DDoS Flood: The bot-flood.service and bot-flood.timer on bot1 and bot2 are responsible for sending periodic DDoS floods to the victim host (192.168.80.100 on port 8888). The flood script is located at /usr/local/lib/.botcache/flood.sh.

4. Student Tasks

- ACCESS Step:
- Credentials: Username cyrano, Password cyrano

- Start Passkey: start

- TRAINING_LEVEL 1: Identify the C2 Beacon Service
- Task: Investigate the running services and identify the service responsible for sending beacon periodically to the C2 Server.
- TYPE of Artifact/Flag Expected: Service name

- TRAINING_LEVEL 2: Determine the Communication Port
- Task: Investigate the service and determine the network port associated with this communication.
- TYPE of Artifact/Flag Expected: Port number

- TRAINING_LEVEL 3: Identify the Persistence Timer
- Task: Determine which system component is responsible for scheduling the C2 beacon service activity.
- TYPE of Artifact/Flag Expected: Timer name

5. Solution Walkthrough & Flags

- TRAINING_LEVEL 1: Identify the C2 Beacon Service
- Methodology:
  1. Log in to the entry host bot1 using the provided credentials.
  2. Enumerate all running and inactive services using the following command:
     ```
     systemctl list-units --type=service --all
     ```
  3. Look for unfamiliar service names or misspellings of legitimate services. Pay attention to services with unusual descriptions or startup behavior.
  4. Identify the service responsible for sending beacon periodically to the C2 Server.
- Expected Flag: bot-beacon.service

- TRAINING_LEVEL 2: Determine the Communication Port
- Methodology:
  1. From the entry host bot1, inspect the service identified in the previous task using the following command:
     ```
     systemctl cat bot-beacon.service
     ```
  2. Pay particular attention to the ExecStart line, which specifies the path of the script launched by the service.
  3. Check the script to find the communication port with the C2 server.
- Expected Flag: 2222

- TRAINING_LEVEL 3: Identify the Persistence Timer
- Methodology:
  1. From the entry host bot1, list all systemd timers using the following command:
     ```
     systemctl list-timers --all
     ```
  2. Identify the timer associated with the C2 beacon service.
- Expected Flag: bot-beacon.timer

6. Knowledge Gained

- Skills Practised:
- Enumerating and analyzing running services and systemd timers.
- Investigating network connections and service configurations.
- Identifying and disabling persistence mechanisms.
- Containing threats by blocking unauthorized network communication.
- Terminating malicious processes and removing malicious artifacts.
- Tools Practised:
- systemctl
- nc (netcat)
- Concepts Practised:
- Linux system administration.
- Systemd service management.

- Network security principles.
- Common attack vectors.
- NICE Role Alignment: Incident Response
- MITRE Techniques Alignment:
- Persistence: T1547.001
- Command and Control: T1071
- Exploitation: T1200